

Lab 6 - MITRE ATT&CK Investigation

Evidence-Based Technique Mapping for SOC Analysis

Lab Type	SOC / MITRE ATT&CK Analysis
Primary Goal	Map observed behavior to ATT&CK only when supported by evidence
Scenarios Used	Phishing, PowerShell, Defender detection, failed local logons
Approach	Evidence first; avoid forced or speculative mappings

1. Objective

The objective of this lab was to practice evidence-based MITRE ATT&CK mapping using activity observed in earlier SOC labs. The focus was not simply to attach ATT&CK labels to alerts, but to determine whether the available evidence actually supported a specific adversary behavior.

A key analyst principle used throughout the lab was: alert severity, product labels, and automated mappings should not replace analyst validation.

2. Scenarios Reviewed

Scenario	Evidence reviewed
Simulated phishing email	Credential-verification link and social-engineering language
PowerShell activity	powershell.exe used to create the EICAR test file
Defender malware detection	Event ID 1116 / EICAR detection
Failed local logons	Event ID 4625, Logon Type 2, localhost source

3. Mapping Decision 1 - Failed Local Logons

The authentication scenario contained multiple Windows Event ID 4625 failures, Logon Type 2, and a localhost source. These events were intentionally generated during the lab and were followed by a successful workstation unlock.

Decision: No ATT&CK technique assigned.

Reason: The evidence only showed failed local authentication attempts. It did not prove password guessing, brute-force tooling, credential theft, or a remote adversary.

4. Mapping Decision 2 - Phishing Link

The simulated phishing email contained a suspicious verification link and social-engineering language intended to pressure the recipient into interacting with the message.

Field	Mapping
Tactic	Initial Access
Technique	T1566.002 - Phishing: Spearphishing Link
Evidence	Suspicious verification link plus phishing-style social engineering

Confidence	High
------------	------

5. Mapping Decision 3 - PowerShell

In the malware-triage lab, PowerShell was used to create the EICAR test file. The Defender/Wazuh event recorded PowerShell as the process involved in the activity.

Field	Mapping
Tactic	Execution
Technique	T1059.001 - Command and Scripting Interpreter: PowerShell
Evidence	powershell.exe was directly observed as the creating process
Confidence	High

6. Mapping Decision 4 - Defender Detection

Microsoft Defender detected the safe EICAR test sample and generated Event ID 1116. This alert represented defensive telemetry, not an ATT&CK technique by itself.

Decision: No separate ATT&CK technique assigned to the antivirus detection.

Reason: ATT&CK should describe observed adversary behavior. The underlying PowerShell behavior was already mapped separately to T1059.001.

7. Final ATT&CK Mapping Table

Scenario	Evidence	Tactic	Technique	Confidence
Simulated phishing email	Suspicious verification link and social engineering	Initial Access	T1566.002 - Spearphishing Link	High
PowerShell activity	powershell.exe observed creating EICAR test file	Execution	T1059.001 - PowerShell	High
Defender EICAR detection	Event ID 1116 / severe AV alert	-	No separate technique assigned	High
Failed local logons	4625 / Logon Type 2 / localhost	-	No technique - insufficient evidence	High

8. Attack Sequence Interpretation

The strongest evidence-supported ATT&CK sequence from the reviewed scenarios was:

Initial Access -> Execution

Initial Access: T1566.002 - Phishing: Spearphishing Link

Execution: T1059.001 - Command and Scripting Interpreter: PowerShell

The failed logons were intentionally left unmapped because the evidence did not support a specific adversary technique. The Defender alert was treated as detection evidence rather than as a separate ATT&CK behavior.

9. Analyst Lessons

Lesson	Why it matters
Do not force mappings	A failed login alone does not prove brute force or credential access
Map behavior, not severity	A high-severity AV alert is not automatically an ATT&CK tactic
Validate automated tags	SIEM/EDR ATT&CK mappings should be checked against the actual evidence
Separate telemetry from behavior	Defender detection is evidence; PowerShell execution is behavior
State confidence	Confidence helps distinguish direct evidence from inference

10. Conclusion

This lab demonstrated evidence-based MITRE ATT&CK mapping across multiple SOC scenarios. The phishing case was mapped to T1566.002 under Initial Access, and the PowerShell activity was mapped to T1059.001 under Execution. Defender telemetry and failed local logons were intentionally not force-mapped where the evidence did not justify a specific technique.

Portfolio summary: Performed evidence-based MITRE ATT&CK mapping for phishing, PowerShell, endpoint detection, and authentication events; validated technique selection, distinguished telemetry from adversary behavior, and documented confidence-based analyst conclusions.